

API SECURITY RISK ANALYSIS REPORT

FutureIntern

Task - 3

Submitted By: THIRUKUMARAN S

CIN: FIT/MAY26/CS8388

Internship: Future Interns – Cyber Security

Internship Task: API Security Risk Analysis

Target API: JSONPlaceholder

Date: May 2026

EXECUTIVE SUMMARY

Application Programming Interfaces(APIs) are fundamental components of modern SaaS platforms, web applications, and mobile applications. This assessment evaluates the JSONPlaceholder API from a security perspective to identify authentication, authorization, data exposure, and information disclosure risks while documenting remediation recommendations.

INTRODUCTION

APIs enable communication between applications, servers, databases, and third-party services. Because APIs often process sensitive information, security assessments are necessary to identify weaknesses that may expose data or functionality.

OBJECTIVES

Analyze API endpoints, assess authentication and authorization controls, identify excessive data exposure, review security headers, explain business impact, and recommend remediation measures.

SCOPE OF ASSESSMENT

Target API: JSONPlaceholder.

Assessment type: Read-only security review.

Activities included documentation review, endpoint testing, authentication analysis, authorization review, and response header inspection.

TOOLS USED

- Postman
- Google Chrome
- Browser Developer Tools
- documentation analysis techniques.

METHODOLOGY

Documentation review, endpoint enumeration, authentication assessment, authorization assessment, header analysis, risk identification, and reporting.

UNDERSTANDING THE TARGET API

JSON Placeholder is a public REST API designed for testing and educational purposes. Available resources include

/users

/posts

/comments

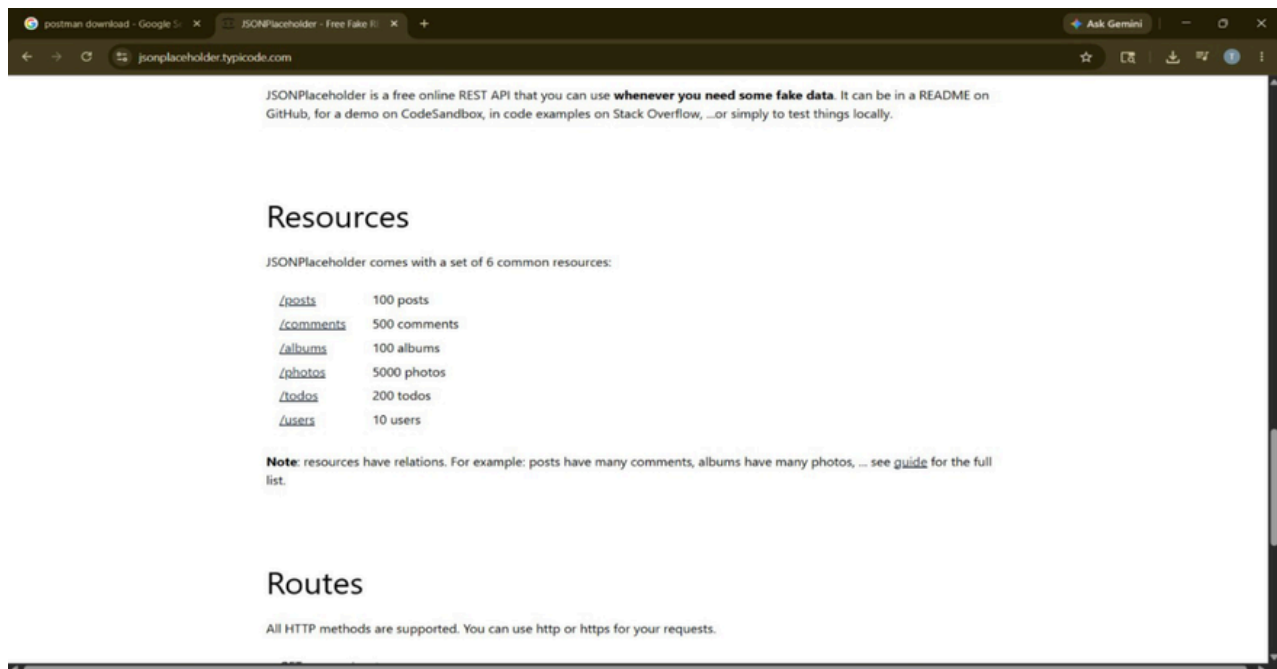
/albums

/photos

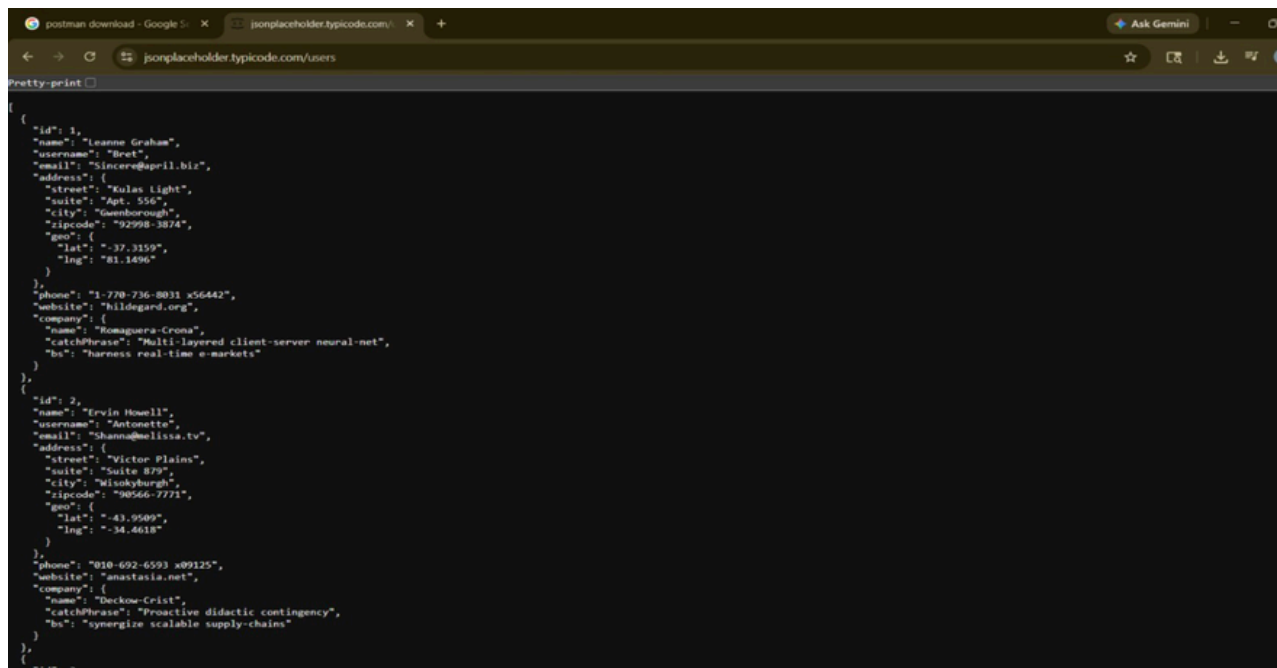
/todos.

EVIDENCE COLLECTION

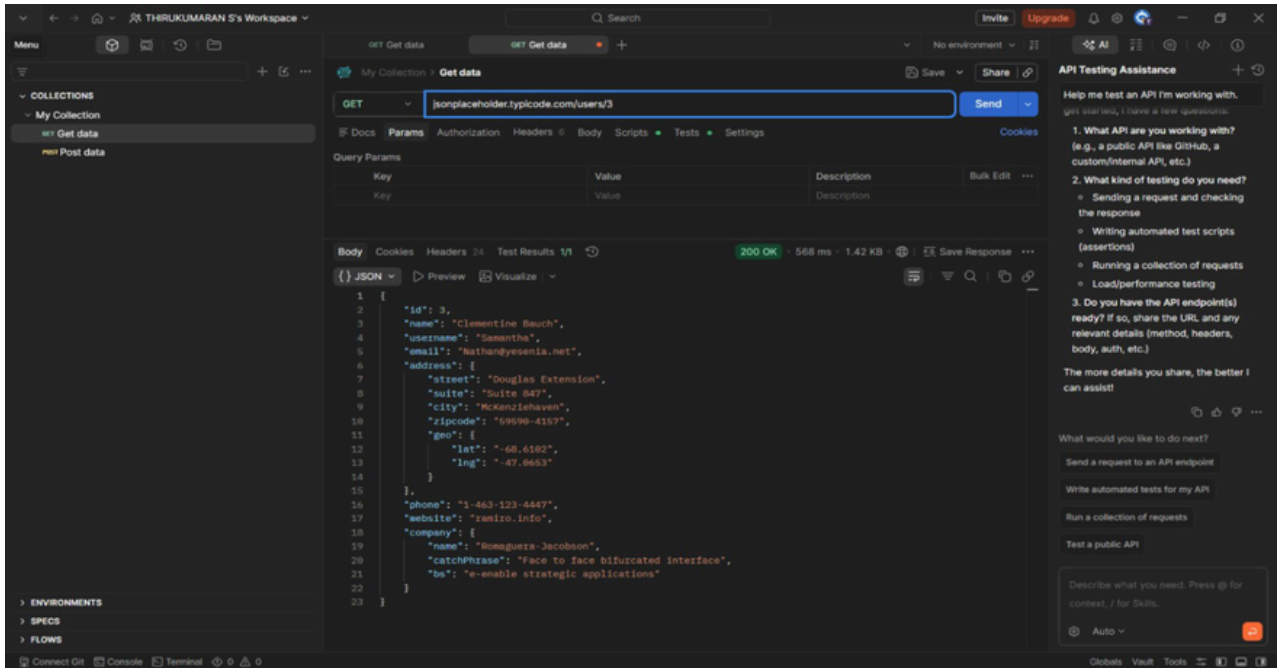
Screenshot 1 – API Documentation: Available resources and endpoints.



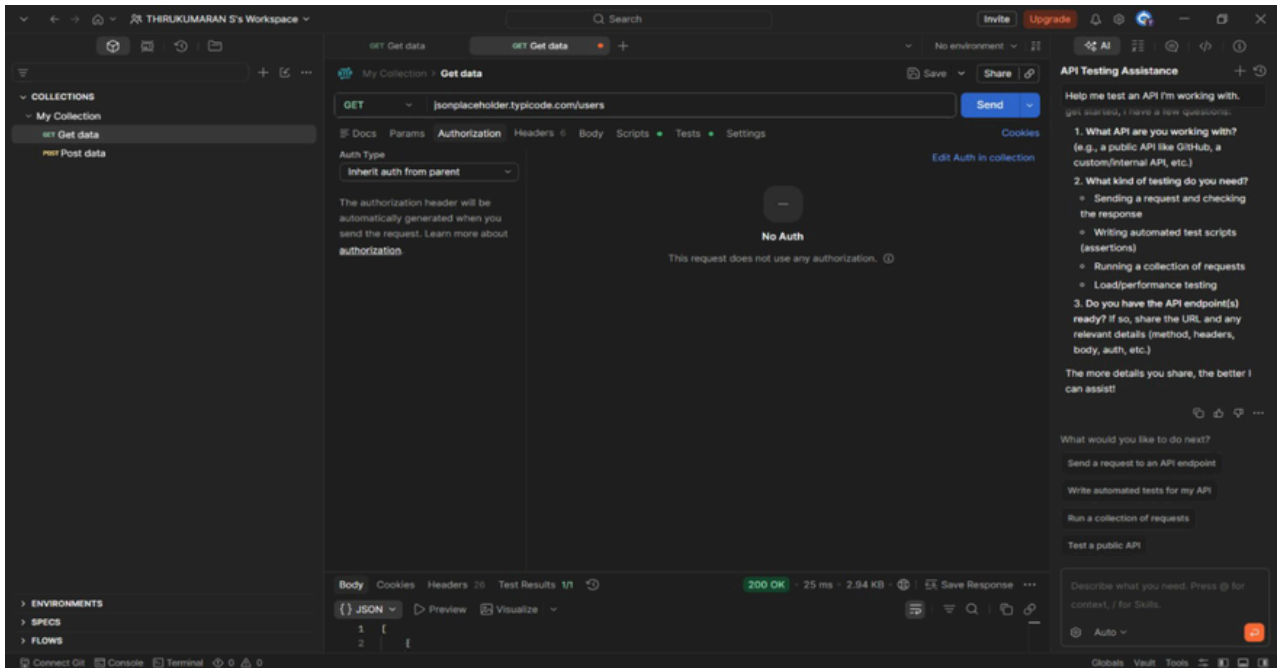
Screenshot 2 – Users Endpoint: User records returned successfully.



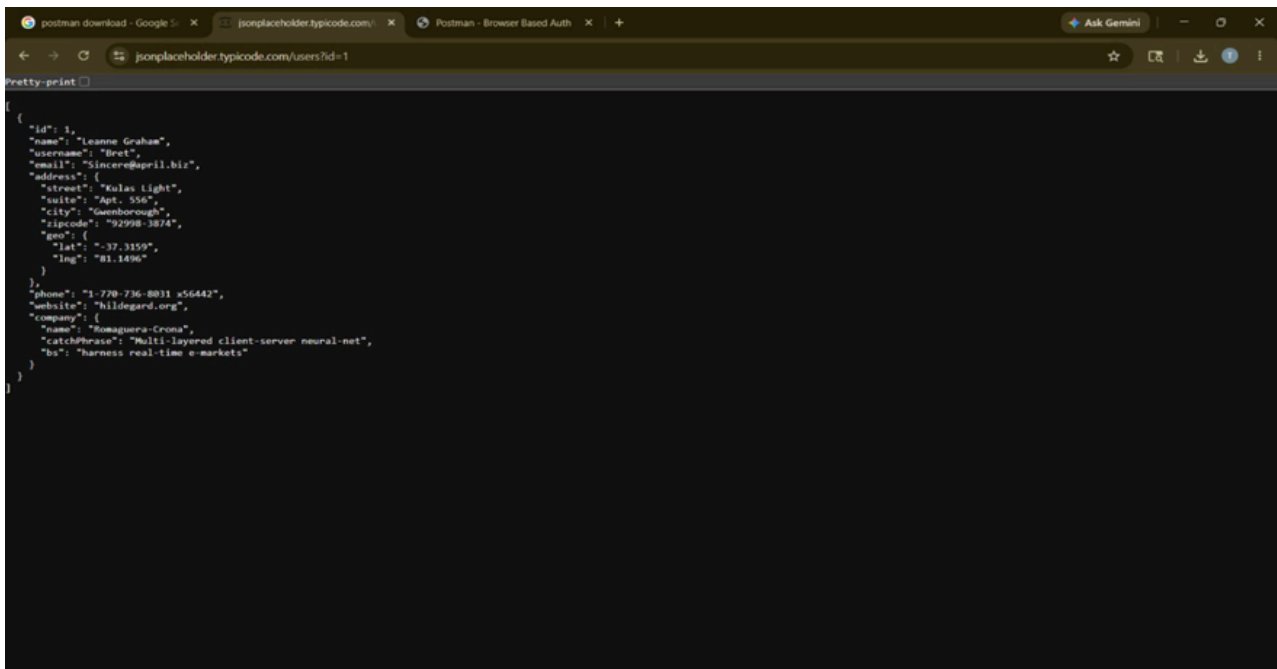
Screenshot 3 – User Record Access: Specific user information retrieved.



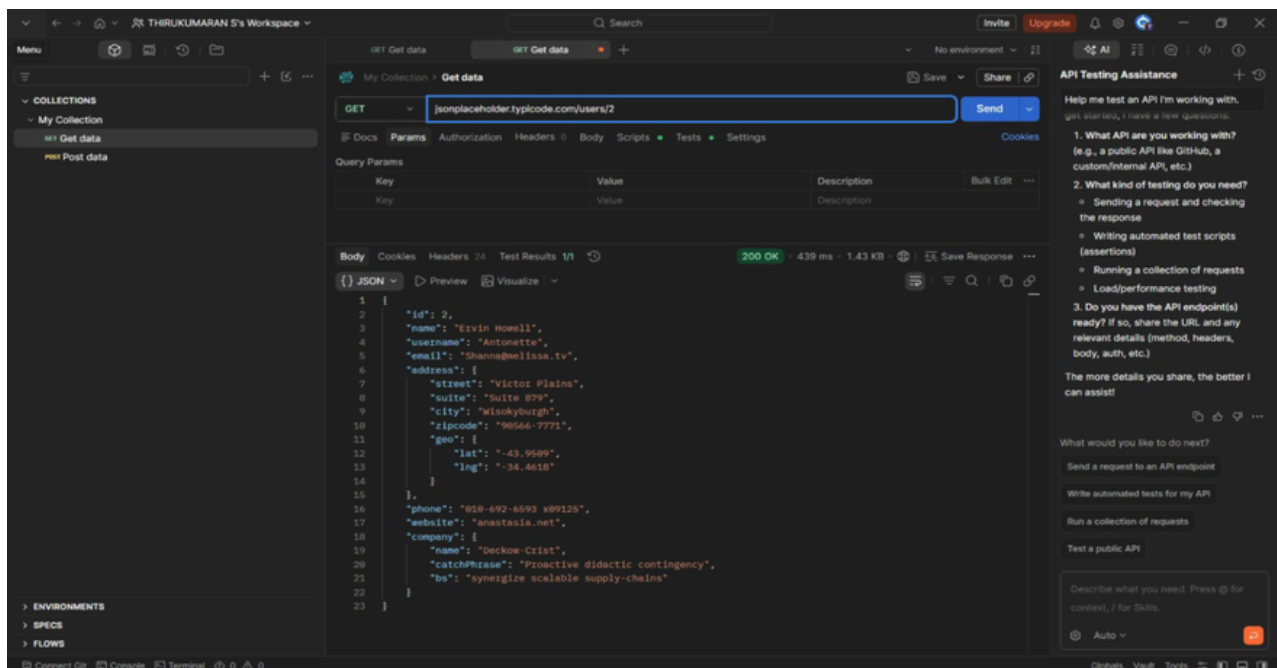
Screenshot 4 – Authorization Review: No Auth configured in Postman.



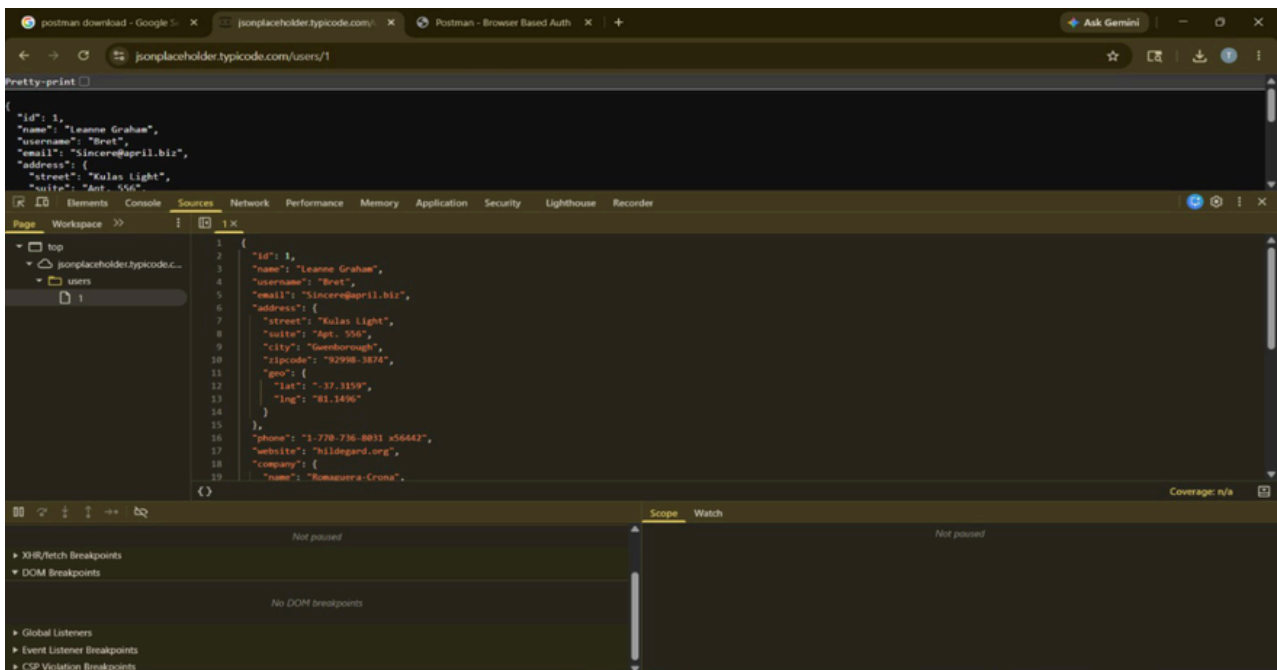
Screenshot 5 – Data Exposure: User details including contact information visible.



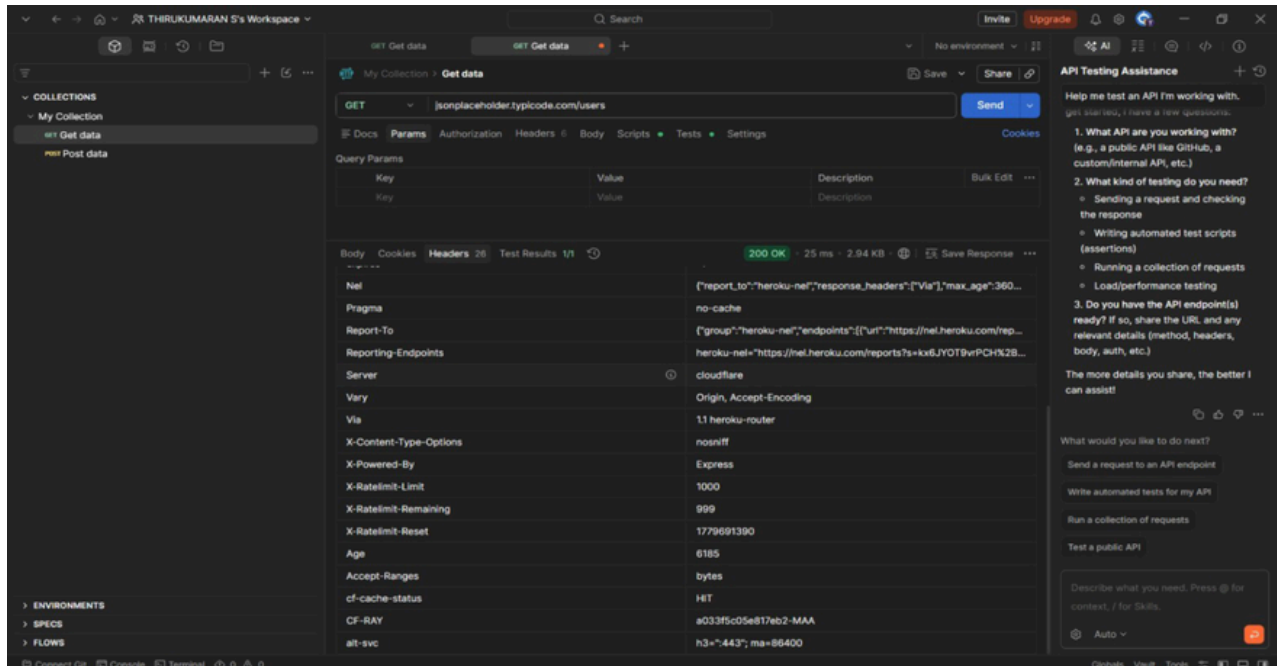
Screenshot 6 – User ID 2 Record Access.



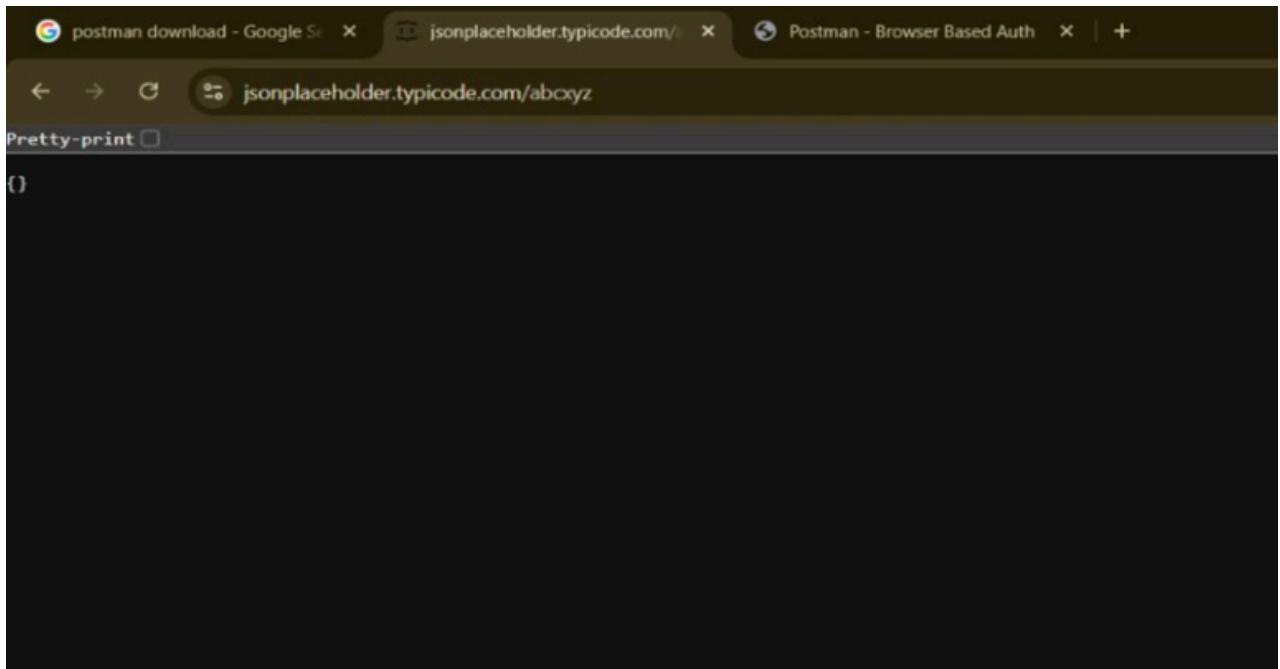
Screenshot 7 – User ID 3 Record Access.



Screenshot 8 – Response Header Analysis.



***Screenshot 9 – Invalid Endpoint
Response.***



RISK ASSESSMENT SUMMARY

- Unauthenticated Endpoint Access–Medium
- Weak Authentication – Medium
- Excessive Data Exposure – Medium
- Broken Object Level Authorization (Educational Observation) – High
- Technology InformationDisclosure –Low

DETAILED FINDINGS

Finding 1: Unauthenticated Endpoint Access (Medium)

The API returned valid responses without requiring authentication credentials.

Business Impact: Unauthorized access to information in a production environment.

Recommendation: Implement OAuth 2.0, JWT, or API key-based authentication.

Finding 2: Weak Authentication (Medium)

The Authorization tab showed 'No Auth' while requests were processed successfully.

Business Impact: Lack of identity verification.

Recommendation: Enforce authentication before processing requests.

Finding 3: Excessive Data Exposure (Medium)

Responses exposed names, emails, addresses, geo-location details, phone numbers, websites, and company information.

Business Impact: Increased privacy and reconnaissance risk.

Recommendation: Apply data minimization principles.

Finding 4: Broken Object Level Authorization (High)

Different user records were accessible by changing identifiers (/users/1, /users/2, /users/3).

Business Impact: Potential exposure of other users' data in real systems.

Recommendation: Implement object-level authorization checks.

Finding 5: Technology Information Disclosure (Low)

Headers revealed technologies such as Cloudflare and Express.

Business Impact: Assists attacker reconnaissance.

Recommendation: Remove unnecessary technology disclosure headers.

SECURITY CONTROLS OBSERVED

Positive controls identified include

- X-Content-Type-Options: nosniff
- Rate-limiting headers (X-RateLimit-Limit and X-RateLimit-Remaining)
- Safe error handling behavior.

RECOMMENDATIONS

- Implement strong authentication
- Enforce authorization checks
- Minimize exposed data
- Remove unnecessary technology disclosure headers
- Continue maintaining rate-limiting and security headers.

CONCLUSION

The API Security Risk Analysis successfully demonstrated the process used by security professionals to assess modern APIs. Although JSONPlaceholder is intentionally public, the findings illustrate common security risks and appropriate remediation strategies for real-world SaaS environments.

REFERENCES

- OWASP API Security Top 10
- JSONPlaceholder Documentation
- Postman Documentation
- Future Interns Task Guidelines.